

MVP Scope — DrishtiMail Forensics

Generated: 2026-08-29 | Rebuilt: 2026-08-31 (from discovery.md + Architecture Update v2) | Reviewed by: Ashutosh Garg
Framing: Value-first — scope is full product breadth; the P0/P1/P2 tiers below order the build without removing anything from scope.

Problem Restatement

Institutions can block malicious email but cannot explain, trace, or evidence it. When a spoofed invoice or a credential-harvesting mail impersonating a Registrar arrives, the security team can quarantine it and still not answer where it came from, which infrastructure sent it, whether it matches a prior incident, or how to hand it to law enforcement in a usable form. Four gaps drive this: semantic (no read on intent independent of keywords), forensic (headers stored but never reconstructed into a trust-aware relay path), attribution (every email treated as an isolated event), and evidentiary (no chain of custody, so findings do not survive legal or disciplinary scrutiny). This build closes all four at full breadth.

Users

Primary: SOC / security analysts — the daily driver, ~60–100 flagged mails per day, needs a verdict and its reasons in under 30 seconds. Cyber forensic investigators — the escalation path, needs relay reconstruction, infrastructure attribution and defensible evidence. Mail administrators — deploy and configure it, and require that mail flow is never at risk.
Secondary: Institutional head / registrar (sponsor and risk owner), end users (staff, faculty, students) as the protected party, law enforcement / cybercrime cell as report consumers, legal / DPO / compliance, CERT-In as nodal agency. The executive dashboard, the end-user reporting path and the M12 evaluation dashboard each give a secondary persona a first-class surface.

MVP Framing

Approach: Value-first
Rationale: The consultant has stated there is no time constraint, and has directed that every deferrable feature remain in scope. The only exclusions are permanent product and ethical boundaries. Architecture Update v2 supplies a P0/P1/P2 build ordering on the assumption that full scope may not be deliverable; that ordering is recorded here as build priority, not as a scope reduction — nothing has been moved out.
Constraint driving scope: Zero budget — free-tier and open-source only. With scope at full breadth and schedule unbounded, this remains the sole binding constraint.
Resourcing: explicitly not a planning constraint. The consultant directed on 2026-08-31 that the whole scope will be built and that team capacity should not be treated as a limit. Downstream skills should size and sequence the full twelve modules without proposing cuts.

Scope: In

Feature	Description	Confidence	Rationale
M1 — Ingestion & Normalisation	Message-file upload (single + bulk archive), pasted headers, mail platform API ingestion, mailbox polling, journaling stream; structure parse, SHA-256 at ingest, write-once original, malformed-message tolerance, deduplication, programmatic analysis endpoint	HIGH	Everything depends on it; hash-at-ingest roots the evidence chain

Feature	Description	Confidence	Rationale
M2 — Detection Engine (NLP/ML)	Six-class classification with calibrated probability, social-engineering cues, payment-fraud sub-patterns, display-name spoofing, lookalike-domain detection, concealment-technique detection, thread-hijack detection, multilingual body analysis, feature attribution, analyst feedback and retraining queue	HIGH	Closes the semantic gap. URL, attachment and scoring responsibilities extracted to M9 and M11 per v2
M3 — Header & Protocol Analysis	Relay-chain parsing, trust-boundary logic, sender-authentication validation with alignment, authentication-results cross-check, forwarding-chain evaluation, header-anomaly and relay-characteristic detection, per-hop table — plus F5 Authentication Semantics : for every result tuple, what it establishes, what it does not establish, and its effect on the investigation	HIGH	Closes the forensic gap and supplies M4 its input. F5 is the feature that most directly answers the "cannot explain" gap
M4 — Origin Traceability & Location	Candidate address extraction, earliest-reliable-origin selection with justification, geographic and network-operator resolution, infrastructure-type classification, mandatory confidence bands, interactive trace map, domain registration intelligence, high-risk domain flags, historical resolution data, enrichment caching	HIGH	Named directly in the problem statement title
M5 — Investigation & Correlation Graph	Indicator extraction, threat-feed correlation, property graph with typed nodes and edges, origin-scenario classification, confidence-scored leads, standard-format indicator export, pivot explorer — plus F6 Campaign Memory : explainable shared-indicator scoring and structural fingerprinting over the HTML tag skeleton; plus F4 First-Contact Baseline : familiarity bands over the institution's own indicator history	HIGH	Closes the attribution gap. F6's structural fingerprint catches a phishing kit reused with different wording and domains, which text similarity misses
M6 — Alerting, Dashboard & Reporting	Real-time alerts with configurable destinations and thresholds, analyst queue, email detail view, executive dashboard, forensic report with evidence-integrity page, admissibility certificate template, case management, full-text and indicator search, end-user reporting intake — plus the interface surfaces for F1, F5, F7 and F8	HIGH	The surface every persona touches
M7 — Evidence Integrity Layer	Role-based access control (5 roles), content masking with audited reveal, configurable retention with automated removal, data-residency enforcement, legal-hold flag — plus F7 Evidence Ledger : evidence references binding every finding to a byte range in the preserved original, a database-enforced append-only hash-chained ledger, a periodic Merkle root exported with each report, and a standalone verification tool that runs with no access to the live system	HIGH	Closes the evidentiary gap. F7 achieves tamper-evidence at zero cost with no external service
M8 — Administration	Protected-brand/individual list, trusted internal mail-server list, allow/block list with expiry, scoring-weight and threshold configuration, model registry that M12 writes to	HIGH	M2, M3 and M11 are undefined without the lists and weights this module owns
M9 — URL & Embedded Content Threat Engine	Hyperlink extraction, attachment static analysis, and F3 Quishing/QR detection across inline images, image attachments and rasterised document pages — all converging on one URL set, then redirect expansion, display-versus-destination comparison, typosquatting check and feed lookup. Undecodable QR codes emit "QR present, undecodable" rather than silence	HIGH	Extracted from M2 per v2. One URL pipeline regardless of how the URL arrived; QR provenance is tagged so M10 can detect body-versus-QR divergence
M10 — Evidence Conflict Detector	Named contradictions between module outputs, each quoting both sides: authenticated but misaligned, reply-path divergence, authentication pass versus content risk, display versus destination, QR versus body divergence, geography versus claim, header versus relay timing, feed versus baseline	HIGH	New per v2. No external data — inputs are entirely internal module outputs. Highest value-per-line feature in the addition
M11 — Explainable Threat Scoring	Transparent weighted-additive model over normalised signals with per-family weight ceilings, conflict adjustment from M10, clamped 0–100. Mandatory output contract: ranked per-signal contributions summing visibly to the total, a confidence band, fixed disclaimer language, and a link from each contribution to its M7 evidence reference. Verdict labels are Low / Elevated / High / Critical	HIGH	Extracted from M2 per v2. An additive model explains itself; the requirement is explanation, so opaque aggregation is disqualified

Feature	Description	Confidence	Rationale
M12 — ML Evaluation & Model Validation	Held-out evaluation with per-class precision, recall and F1, test-set size, and explicit statement of what the corpus does not cover. Admin-only, deliberately off the per-email path	HIGH	New per v2. Surfaces the training-data gap on a dashboard rather than hiding it inside a metrics claim

Scope: Out

Feature	Why Out	Deferred to
Deanonimisation of individuals	Permanent product and ethical boundary. The platform attributes infrastructure and produces confidence-scored investigative leads; it never asserts identity, and the UI must never imply it. Reaffirmed by v2 §5.6 as non-negotiable.	Never
Acting as primary MTA / inline blocking	Consultant decision: out-of-band journaling only, mail flow never at risk. Inline blocking is conditional on the system first being proven and trusted in the live mail path.	Future phase
Full dynamic malware sandbox / detonation chamber	Integration hook only. Attachment static analysis in M9 covers the detection need.	Integration hook only
Offensive actions — takedown, hack-back, active probing of attacker infrastructure	Passive enrichment only.	Never
Endpoint (EDR) telemetry, network packet capture	Outside the email-forensics problem domain.	Out of product scope
Encrypted-body decryption (S/MIME, PGP) without the institution's own keys	Not technically available without key custody.	Out of product scope
External blockchain anchoring of evidence roots	Downgraded from in-scope to optional by v2 §5.7. The hash-chained ledger with exported Merkle root achieves tamper-evidence at zero cost; an external anchoring service adds dependency and reset risk without adding capability at MVP.	Optional enhancement

Build Priority

From Architecture Update v2 §7. This orders the build; it does not reduce scope.

P0 — build first, the demonstration depends on these

1. F7 Evidence Ledger (M7) — everything else writes into it, so it must exist first
2. F5 Authentication Semantics (M3) — cheapest to build, highest explanatory value
3. F3 QR Detection into the URL engine (M9) — self-contained, no external dependency
4. F8 Explainable Scoring (M11) — needs F5 and the M9 URL signals before it is meaningful
5. F1 Evidence Conflict Detector (M10) — needs F5 and M2 outputs to compare

P1 — materially strengthens the demonstration

6. F6 Campaign Graph at prototype scale (M5)
7. F4 First-Contact Baseline (M5) — rides on the index F6 builds, nearly free once F6 exists

P2 — build last, be honest about the limitation

8. F2 ML Evaluation Dashboard (M12) — the dashboard is a day's work; the data question behind it may not resolve at all. Build it, run it against whatever defensible set exists, and present the limitation openly rather than deferring the feature.

Dependency note: F8 cannot precede F5, F3 and M3 emitting signals — a scorer with two inputs demonstrates worse than no scorer. F4 cannot be demonstrated before the F6 index exists. F1's rule set grows with every module completed, so its rule table stays open until the freeze.

Key User Journeys

1. SOC analyst → opens a flagged email from the queue → reads verdict, 0–100 score and ranked contributing signals summing visibly to the total → closes as low-risk or escalates to a case, inside 30 s — [M1, M2, M11, M6]
2. Forensic investigator → opens an escalated case → reads the authentication semantics panel for what the result does and does not establish → walks the hop table with sub-trust-boundary hops marked unverified → lands on the earliest reliable IP with geolocation, ASN, infrastructure type and domain age, each with confidence bands — [M3, M4, M6, M8]
3. SOC analyst → opens an email whose body has no suspicious links → the URL engine decodes a QR code in an attached invoice image, expands its redirect chain and lands on a typosquat domain → the conflict detector names the QR-versus-body divergence, quoting both sides — [M9, M10, M6]
4. Analyst or investigator → opens the correlation graph → sees shared origin infrastructure and a matching structural fingerprint linking to earlier incidents → the campaign forms with its shared indicators listed, and the first-contact panel distinguishes a new domain from established infrastructure → pivots on a node to a related case — [M5, M6]
5. Investigator → exports the forensic report from a closed case, every finding carrying an evidence reference to a byte range in the original → a third party alters one byte and runs the standalone verifier → FAIL; restores it → PASS — [M6, M7]

Success Metrics

Not defined as targets — deferred to Open Questions.

What changed with v2: M12 makes measurement itself a deliverable. Rather than committing to a number in advance, the system reports per-class precision, recall and F1 on a stated held-out set alongside the test-set size and an explicit statement of what the corpus does not cover. That is an improvement in honesty, not a resolution — there is still no agreed target any module is accepted against. The source document's original KPIs ($F1 \geq 0.95$, $FPR \leq 2\%$, $p95 \leq 3$ s, relay reconstruction $\geq 90\%$, clustering recall $\geq 85\%$) remain unadopted: they were written against a 36-hour scope, and F1 measured on public corpora characterises the corpus rather than institutional mail.

Constraints

- Timeline: no fixed deadline — scope-driven, not time-boxed. Target is the full product.
- Budget: none — student team. Free-tier and open-source only; no paid or subscription service may be assumed anywhere in the design. Hard constraint.
- Tech: **PostgreSQL** as primary store, per the consultant's decision on 2026-08-31. This follows from v2's F7 design, which requires a database-enforced append-only ledger (insert-only role permissions, update and delete blocked) and evidence-reference constraints enforced by the database rather than by convention. v2 also names a relational store with recursive queries as the safe default for F6's graph at prototype scale. Remaining stack decisions sit in arch.md.
- Other:
- Ingestion primarily via Google Workspace / Gmail API; generic mailbox polling also in scope.
- Out-of-band analysis only — a copy is analysed, no real-time blocking, mail flow never at risk.
- Retention: headers 1 year, bodies 90 days, both institution-configurable, with automated purge in scope. The retention rule for the F6 graph and F4 indicator index is unresolved — see Open Questions.
- Threat intel: free tiers only — VirusTotal public API (4 req/min), URLhaus, PhishTank — plus manual CSV/Excel import. Per v2, F6 and F4 both function with zero feed calls, so enrichment is an enhancement rather than a

dependency.

- No institutional mail for training; public corpora only. No non-English phishing corpus identified for the multilingual requirement.
- No certified forensic examiner assigned; evidence must be emitted ready for later certified review.
- No existing SIEM; the platform builds its own dashboard.
- Data residency within Indian jurisdiction (CERT-In). Compliance surface: DPDP Act 2023, CERT-In 2022 directions, BSA 2023 §63, IT Act 2000.
- Geolocation is probabilistic, not evidentiary — every location output carries a confidence band and caveat.
- Nothing on the demonstration path may make a live external call, including QR redirect chains and feed lookups. The history index must be seeded with 40–60 pre-ingested messages before any demonstration, and that seeding must be stated aloud.

Assumptions

- A mail platform account with API access is available for development and demo — inferred; the consultant confirmed the platform but not the test account
- Public phishing corpora are legally usable for training and redistribution in a demo context — inferred; v2 raises this as an unresolved licence question under F2
- Free-tier quotas for the chosen threat feeds remain available and unchanged through the build — inferred; severity reduced by v2, since F6 and F4 need no feed calls
- Geolocation data and other open-source components remain free under terms compatible with this use — inferred
- QR decoding and PDF rasterisation libraries can be bundled under their licences — inferred; v2 flags ZBar as LGPL and PyMuPDF as AGPL, which matters if the prototype is distributed
- The demo dataset is prepared and cached in advance; nothing in a live demo depends on an external service responding — v2 §8 rule
- Team size is six — from the source document; scope has since roughly tripled against that figure

Open Questions

1. What are the success metrics for this build? — no agreed target exists for any module. M12 measures and discloses but commits to nothing. ARCH_PROPOSER and ESTIMATOR both read this section.
2. What replaces the institution-donated training data? — unchanged by v2 and now more visible, since M12 surfaces the gap rather than hiding it. Public corpora reintroduce era-and-encoding bias, and no non-English corpus has been identified for the multilingual requirement.
3. Is a mail platform account with API access provisioned? — blocks the primary ingestion route.
4. What is the minimum history volume before the F4 first-contact signal is trusted rather than suppressed? — 1,000 messages proposed as default; needs a decision.
5. Which QR decoder, given the licence question? — ZBar is LGPL, PyMuPDF is AGPL; this matters if the prototype is distributed or open-sourced.
6. Who authors the F5 semantics prose? — the most user-visible text in the product, and it must be technically exact. Assign one named person, not "the team".
7. Does the F8 conflict adjustment need its own calibration set, or is expert judgement on the weights acceptable for the prototype?
8. What is the retention rule for the F6 graph and the F4 indicator index? — indicator history is precisely the data most useful when kept longest and most sensitive when kept at all.

9. How is enrichment reconciled with the free-tier lookup quota? — **reduced in severity by v2**: ~5,760 lookups/day against a 10,000 messages/hour target remains arithmetically impossible for per-message live lookup, but F6 and F4 now function on self-generated data with zero feed calls, so this constrains an enhancement rather than the core path.

Resolved since the previous revision:

- *Is zero-cost tamper-evident anchoring viable?* — **yes**. v2 §5.7's hash-chained append-only ledger with an exported Merkle root achieves tamper-evidence with no external service, no distributed ledger and no budget. External anchoring is downgraded to optional.

- *Does application-enforced audit chaining meet the evidentiary bar?* — **moot**. The move to PostgreSQL makes the ledger database-enforced: insert-only role permissions, update and delete blocked, evidence references enforced by constraint.

- *Is full scope deliverable by this team?* — **closed by decision, not by analysis**. The consultant directed on 2026-08-31 that the whole scope will be built and that resourcing is not a constraint to plan against. All twelve modules stay IN. This is a legitimate call for an unbounded learning project, and it is recorded as a decision rather than a finding: no analysis established that full scope fits the team, and none was asked for. The practical effect is that ESTIMATOR's total becomes informational rather than a go/no-go gate, and the P0/P1/P2 tiers become demonstration-readiness sequencing rather than triage.

Effort Signals

⚠ Deferred to ARCH_PROPOSER — sizing without architecture context produces noise, not signal.

Confidence Notes

- Scope framing: WARN — this document is titled MVP Scope but describes full product scope. Scope: Out holds only permanent boundaries plus one capability v2 downgraded to optional. The P0/P1/P2 tiers order the build without removing anything.
- Timeline: WARN — no fixed deadline. Scope is the fixed side of the trade and schedule is free. Any downstream sprint plan or estimate must assume a window the client has not supplied, and that assumption now spans twelve modules rather than eight.
- Success Metrics: LOW — no agreed target. Improved in honesty by M12, unresolved in substance.
- Database: this rebuild records PostgreSQL, reversing the MongoDB decision of 2026-08-31. The reversal is not a preference change — v2's F7 design requires database-enforced append-only writes and evidence-reference constraints, which MongoDB does not provide. arch.md must be revised to match; until it is, the two documents disagree.
- Provenance: rebuilt from discovery.md and Architecture Update v2 after the previous mvp-scope.md was deleted. The previous version recorded 8 modules; this records 12. v2 was authored against prd.md v1 and states it supersedes that document's module list while leaving its user stories and acceptance criteria intact.
- Source agreement: v2 does not contradict discovery.md. Where it departs from the original Business Analysis Document, it is because the zero-budget constraint post-dates that document.
- Scope growth: eight features and four modules were added by v2 without anything being removed. The consultant has since directed that the full scope be built regardless of team capacity, which closes the deliverability question by decision. Recorded plainly because the decision was made without a sizing analysis in front of it — ESTIMATOR has not yet run.

Source Artifacts

- discovery.md — DrishtiMail Forensics discovery, 2026-08-29: problem context and four capability gaps, three primary and five secondary user groups, constraints from the source BAD and an 11-question consultant Q&A.

- drishtimail_architecture_v2 (2).pdf — Architecture Update v2, 2026-08-29: additive integration of 8 features into 12 modules, per-feature data and verification status, P0/P1/P2 build priority, demonstration workflow, and effect on existing open questions. Authored against prd.md v1.